REDOPS SECURITY ASSESSMENT REPORT

Automated Enterprise Red Team Assessment & Attack Simulation Platform
Assessment Date: November 05, 2026 - 20:14:01 UTC | Classification: **CONFIDENTIAL / AUTHORIZED SECURITY ASSESSMENT**

1. Executive Summary & Assessment Scope

This document presents the technical findings, topological graph analysis, and simulated attack chains evaluated by the RedOps platform. Testing was conducted exclusively within authorized laboratory scopes and strictly enforce allowlist policies. The assessment evaluated network boundaries, exposed daemon services, correlated CVE records, and synthesized multi-hop lateral movement attack paths toward enterprise crown jewel assets.

Authorized Scope / Allowlist	Description	Status
127.0.0.1	Safe local testing environment	APPROVED
localhost	Local system loopback alias	APPROVED
172.28.0.0/16	Isolated private Docker network for RedOps assessment	APPROVED
172.28.0.10	Perimeter Reverse Proxy & Firewall simulation	APPROVED
172.28.0.20	Internal Spring Boot / Tomcat Application server	APPROVED
172.28.0.30	PostgreSQL & Redis data stores	APPROVED
172.28.0.40	Domain Controller and Kerberos authentication server	APPROVED

2. Discovered Assets & Attack Surface

Host / IP	Hostname	OS / Role	Criticality	Open Ports
172.28.0.10	gw01.corp.internal	Gateway (Linux)	**HIGH**	22, 80, 443
172.28.0.20	app-portal.corp.internal	Web Server (Linux)	**HIGH**	8080, 8009, 22
172.28.0.30	db-cluster01.corp.internal	Database (Linux)	**CRITICAL**	5432, 6379
172.28.0.40	dc01.corp.internal	DC (Windows)	**CRITICAL**	88, 389, 445

3. Correlated Vulnerabilities (NVD / CVE)

CVE ID	Target Host:Port	CVSS / Severity	Vulnerability Title & Remediation
CVE-2022-0543	172.28.0.30:6379	10.0 CRITICAL	**Redis Lua Sandbox Escape Remote Code Execution** Remediation: Upgrade redis-server package to patched distribution release. Enforce requirepass and bind to localhost only.
CVE-2020-1472	172.28.0.40:445	10.0 CRITICAL	**Microsoft Netlogon Cryptographic Flaw Elevation of Privilege (Zerologon)** Remediation: Apply Microsoft security patch KB4557222 and enforce Secure RPC for all Netlogon connections via registry.
CVE-2022-22965	172.28.0.20:8080	9.8 CRITICAL	**Spring Framework RCE via DataBinder Access Log Manipulation (Spring4Shell)** Remediation: Upgrade Spring Framework to 5.3.18 or 5.2.20+. Update Tomcat to 10.0.20, 9.0.62, or 8.5.78.

CVE-2020-1938	172.28.0.20:8009	**9.8 CRITICAL**	**Apache Tomcat AJP Connector File Read/Inclusion (Ghostcat)** Remediation: Disable the AJP connector in server.xml if not required, or bind to 127.0.0.1 and configure 'requiredSecret'.
CVE-2022-1552	172.28.0.30:5432	**8.8 HIGH**	**PostgreSQL Autovacuum and Index DDL Privilege Escalation** Remediation: Upgrade PostgreSQL to 12.11, 13.7, 14.3 or higher.
CVE-2021-42287	172.28.0.40:389	**8.8 HIGH**	**Active Directory Kerberos Privilege Escalation (sAMAccountName Spoofing)** Remediation: Install KB5008102 and KB5008380 security updates immediately across all domain controllers.
CVE-2021-23017	172.28.0.10:80	**8.5 HIGH**	**Nginx 1-Byte Memory Overwrite in DNS Resolver** Remediation: Upgrade nginx to version 1.20.1, 1.21.0 or higher. Disable dynamic resolver directive if unused.

4. Graph-Based Attack-Path Analysis (NetworkX)

The RedOps graph engine modeled topological asset connectivity and CVE exploitability. Chained paths identify multi-step escalation routes from perimeter vectors to crown jewels.

• Secondary Domain Hijack Path (AJP Exposure -> Zerologon DC Takeover) (Risk Score: 10.0/10.0 [CRITICAL])

Trajectory: *App Portal Perimeter (172.28.0.20:8009)* → *Domain Controller (172.28.0.40:445)*
Description: Direct attack trajectory bypassing boundary controls through exposed Tomcat AJP port, chaining to internal Domain Controller via Zerologon for forest-level privilege dominance.

• Primary Enterprise Compromise Chain (Perimeter -> RCE -> Database Exfiltration) (Risk Score: 9.9/10.0 [CRITICAL])

Trajectory: *External Reconnaissance (172.28.0.10:80)* → *Internal Database (172.28.0.30:6379)*
Description: Multi-stage chained attack path enabling an unauthenticated perimeter attacker to exploit Spring4Shell on the application server, pivot to internal Redis on port 6379, and achieve complete database compromise.

5. AI Reasoning & Threat Narrative (LLM Module)

Engine: local_rule_engine

Security Analysis Narrative: The assessment identifies a high-probability lateral movement path originating from the perimeter reverse proxy. The primary vulnerability CVE-2022-22965 (Spring4Shell) in the enterprise application tier provides unauthenticated command execution. Because the application server resides in the same internal security zone as the database cluster without microsegmentation, an attacker can directly reach the unauthenticated Redis port (6379) and execute CVE-2022-0543 (Lua Sandbox Escape), yielding root-level persistence on the crown-jewel database host.

Limitations & Advisory Notice: Advisory AI reasoning generated based on topological evidence and CVSS 3.1 scoring. LLM findings are bounded to non-destructive analysis and do not confirm live payload execution without controlled human-approved simulation.

6. Controlled Simulation Observations

Scenario Code & Name	Target	Approved By	Status & Observations

SIM-DISC-01 Safe Network Port & Service Footprinting	172.28.0.10:80	security_officer_admin	**[COMPLETED]** Verified open perimeter attack surface on Gateway host. Ports 80 and 443 accept connections.
SIM-EXPLOIT-04 Non-Destructive Vulnerability Signature Verification	172.28.0.20:8080	security_officer_admin	**[COMPLETED]** Spring4Shell signature matched on endpoint /api/v1/health. Target application is exposed to remote exploitation.

7. Prioritized Remediation Roadmap

Priority Level	Target Focus	Defensive Action Plan
P0 - IMMEDIATE	app-portal (172.28.0.20)	Apply vendor patches for Spring4Shell (CVE-2022-22965) and disable Tomcat AJP 8009 (Ghostcat).
P1 - HIGH	db-cluster01 (172.28.0.30)	Upgrade Redis package, enforce 'requirepass' authentication, bind 6379 to 127.0.0.1.
P2 - MEDIUM	dc01 (172.28.0.40)	Deploy KB4557222 to block Zerologon Netlogon spoofing.
P3 - ARCHITECTURAL	All Lab Segments	Implement network microsegmentation between DMZ and database clusters.